

Class 18 APT, DNS Poisoning & Footprinting For SOC L1

DNS Footprinting

DNS Footprinting is the process of collecting information about a target organization by querying its DNS (Domain Name System) records.

It is a reconnaissance (information gathering) technique used before launching an attack.

Important: DNS Footprinting is **not hacking**. It simply gathers publicly available DNS information.

Attacker's Goal

The attacker's goal is to:

- Collect as much information as possible.
 - Stay undetected.
 - Identify systems that may be vulnerable to attack.
-

What Attackers Try to Find

1. Subdomains

Find hidden or public subdomains.

Examples:

```
admin.company.com  
vpn.company.com  
mail.company.com  
dev.company.com
```

Purpose:

- Discover admin panels, development servers, VPN portals, etc.

2. Internal Services

Identify publicly accessible services.

Examples:

```
vpn.company.com  
portal.company.com  
remote.company.com
```

Purpose:

- Find remote access points that can be targeted.

3. Mail Servers (MX Records)

DNS **MX (Mail Exchange)** records show which server handles email.

Example:

```
company.com  
  |  
MX Record  
  |  
mail.company.com
```

Purpose:

- Target email servers for phishing or email-based attacks.

4. Public IP Addresses

Find the public IP addresses associated with the domain.

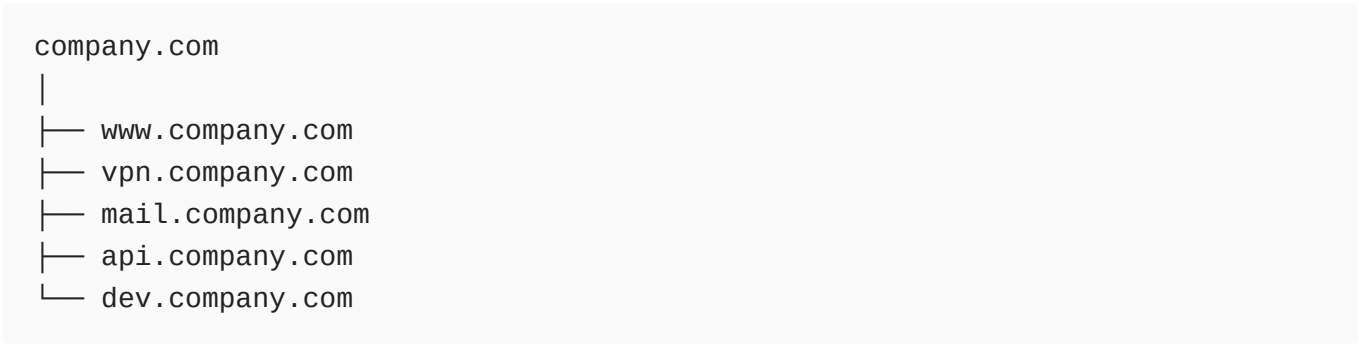
Purpose:

- Identify servers that are exposed to the Internet.
- Scan them for open ports and vulnerabilities.

5. Infrastructure Layout

Understand how the organization's network is structured.

Example:



This helps attackers map the organization's infrastructure.

6. DNS Record Enumeration

Attackers query different DNS record types such as:

Record	Purpose
A	Maps a domain to an IPv4 address
AAAA	Maps a domain to an IPv6 address
MX	Mail server information
NS	Name servers
CNAME	Alias of another domain
TXT	Verification records, SPF, DKIM, DMARC, etc.

SOC Perspective

A SOC analyst watches for:

- Large numbers of DNS queries.
- DNS enumeration attempts.
- Queries for many subdomains in a short period.

- DNS requests from unusual or unknown IP addresses.
 - DNS tunneling (possible data exfiltration).
-

Example SOC Scenario

Source IP: 185.221.x.x

Queries:

admin.company.com

vpn.company.com

mail.company.com

api.company.com

dev.company.com

SOC Analysis

Validate

- Confirm the DNS logs.
- Verify the source IP and timestamps.

Investigate

- One external IP is querying many subdomains.
- This behavior is unusual.

Correlate

- Check:
 - Firewall logs.
 - IDS/IPS alerts.
 - Web server logs.
 - Threat intelligence.

Enrich

- Check the reputation of the source IP.
- Determine whether it belongs to a known scanner or attacker.

Decide

- Multiple DNS enumeration requests indicate **DNS Footprinting (Reconnaissance)**.

Escalate

- Monitor the IP for follow-up scanning or attacks.
- Block the IP if it continues malicious activity.
- Notify the security team if necessary.

DNS Footprinting is a reconnaissance technique used to gather information about a target by querying its DNS records. Attackers use it to discover **subdomains**, **VPN portals**, **mail servers (MX records)**, **public IP addresses**, and the organization's infrastructure. From a SOC perspective, repeated DNS enumeration requests, especially for multiple subdomains from the same source, may indicate reconnaissance activity. Analysts correlate DNS logs with firewall and IDS alerts to determine whether the activity is part of an attack.

SOC Indicator: DNS Footprinting

As a SOC analyst, if you see DNS queries like:

```
admin.site.com
dev.site.com
vpn.site.com
test.site.com
mail.site.com
api.site.com
```

from the **same source IP** within a short time, this is **not normal user behavior**.

Why is it Suspicious?

A normal user usually visits:

- `www.site.com`
- `mail.site.com` (sometimes)

An attacker, however, tries to **enumerate many subdomains** to discover exposed services.

This activity is called **DNS Reconnaissance (DNS Footprinting)**.

If the Attacker is Successful

The attacker may discover:

- ✓ All public subdomains.
- ✓ VPN portals (`vpn.site.com`).
- ✓ Admin panels (`admin.site.com`).
- ✓ Development or test servers (`dev.site.com` , `test.site.com`).
- ✓ Mail servers (MX records).
- ✓ Public IP addresses.
- ✓ Internal naming conventions.
- ✓ The organization's overall infrastructure.

This is known as **infrastructure leakage**, because the attacker gains valuable information that can be used in later attack stages.

SOC Example

DNS Logs

```
Source IP: 185.221.x.x
```

```
Queries:
```

```
admin.site.com
```

```
vpn.site.com
```

```
dev.site.com
```

```
test.site.com
```

```
mail.site.com
```

```
api.site.com
```

SOC Analysis

Validate

- Confirm the DNS logs and timestamps.
- Verify all queries came from the same source IP.

Investigate

- Count how many subdomains were queried.
- Check whether the source is internal or external.

Correlate

- Review:
 - Firewall logs.
 - IDS/IPS alerts.
 - Web server logs.
 - Threat intelligence.

Enrich

- Check the IP reputation.
- Determine if it's a known scanner, bot, or attacker.

Decide

- Multiple subdomain lookups in a short period indicate **DNS Footprinting (Reconnaissance)**.

Escalate

- Monitor for follow-up activity such as:
 - Port scanning.
 - Vulnerability scanning.
 - Brute-force attacks.
- Block the source IP if it continues malicious behavior.

Easy Trick for Interviews

Whenever you see:

```
admin.site.com
vpn.site.com
dev.site.com
test.site.com
```

Think:

Many subdomain lookups = Reconnaissance = DNS Footprinting

The attacker is **collecting information**, not yet exploiting the target.

If I observe DNS queries for multiple subdomains such as **admin.site.com**, **vpn.site.com**, **dev.site.com**, and **test.site.com** from the same source in a short period, I would consider it a strong indicator of **DNS Footprinting**. This is not typical user behavior; it suggests reconnaissance, where an attacker is mapping the organization's infrastructure. If successful, they can identify public services, VPN gateways, mail servers, and internal naming patterns, which can be used to plan future attacks. From a SOC perspective, I would validate the logs, correlate them with firewall and IDS alerts, enrich the source IP with threat intelligence, and monitor or block the source if malicious activity continues.

SOC analysts monitor **DNS logs** to identify **reconnaissance (footprinting)** activity before an attacker launches an actual attack.

Key Indicators

1. High Number of DNS Queries from One IP

- A single IP sends a large number of DNS requests in a short period.
- This may indicate automated DNS enumeration.

2. Sequential Subdomain Queries

- The same source queries many subdomains one after another.

Example:

```
admin.company.com
vpn.company.com
mail.company.com
dev.company.com
api.company.com
test.company.com
```

This is **not normal user behavior** and often indicates DNS footprinting.

3. Unusual External IP Querying Many Domains

- An unknown external IP repeatedly queries the organization's DNS records.
 - This may indicate an attacker trying to map the company's infrastructure.
-

Example

Source IP: 45.12.x.x

Queries:

admin.company.com

vpn.company.com

mail.company.com

dev.company.com

Conclusion

Active Reconnaissance (DNS Footprinting)

The attacker is trying to discover publicly accessible services before launching an attack.

SOC Analysis (Your 6-Step Workflow)

1. Validate

- Verify the DNS logs and timestamps.
- Confirm all queries originated from **45.12.x.x**.

2. Investigate

- Count the number of DNS queries.
- Check which subdomains were requested.
- Determine whether the source IP is internal or external.

3. Correlate

- Review:
 - Firewall logs (any connections after DNS lookups?)
 - IDS/IPS alerts
 - Web server logs
 - SIEM alerts

4. Enrich

- Check the reputation of **45.12.x.x** using threat intelligence.
- Determine whether it is a known scanner, bot, or malicious IP.

5. Decide

- Multiple sequential subdomain queries from the same external IP indicate **DNS Footprinting (Reconnaissance)**.

6. Escalate

- Monitor the IP for follow-up activities such as:
 - Port scanning
 - Vulnerability scanning
 - Brute-force attempts
- Block the IP if malicious activity continues.
- Inform the Incident Response or Network team if required.

From a SOC perspective, DNS footprinting is detected by looking for a **high number of DNS queries from a single IP, sequential queries for multiple subdomains, and unusual external IPs querying many internal domains**. For example, if an external IP queries `admin.company.com`, `vpn.company.com`, `mail.company.com`, and `dev.company.com` within a short time, it is a strong indicator of **active reconnaissance**. I would validate the DNS logs, correlate them with firewall and IDS/IPS logs, enrich the source IP with threat intelligence, and monitor or block the source if the reconnaissance continues.

DNS Poisoning

DNS Poisoning (also called **DNS Cache Poisoning**) is an attack where an attacker **injects fake DNS records** so that a domain name resolves to the **wrong IP address**.

In simple words:

Correct Domain → Wrong IP Address

As a result, users are redirected to a fake or malicious website without realizing it.

Normal DNS Resolution

```
User
|
www.bank.com
|
DNS Server
|
Returns: 104.20.10.5 ✓
|
Real Bank Website
```

The user reaches the legitimate website.

DNS Poisoning

```
User
|
www.bank.com
|
Compromised DNS Server
|
Returns: 185.221.x.x ✗
|
Fake Bank Website
```

The user thinks they are visiting the real website but is actually sent to the attacker's server.

Attacker's Goals

1. Redirect Users to Fake Websites

- Redirect users to phishing pages that look identical to the real website.

2. Steal Credentials

- Trick users into entering:
 - Username
 - Password
 - Banking credentials
 - Credit card details

3. Deliver Malware

- Redirect users to websites that automatically download malware or ransomware.

SOC Perspective

SOC analysts look for:

- Sudden changes in DNS responses.
- A trusted domain resolving to an unexpected IP address.
- Multiple users being redirected to the same suspicious IP.
- DNS responses that don't match known DNS records.
- Spikes in phishing or malware alerts after DNS queries.

Example SOC Scenario

User Requested:
www.company.com

Expected IP:
104.20.10.5

Returned IP:
185.221.x.x

SOC Analysis (Your Workflow)

1. Validate

- Verify the DNS logs.
- Compare the returned IP with the legitimate DNS record.

2. Investigate

- Check:
 - DNS server logs.
 - Firewall logs.
 - Proxy logs.
 - Endpoint activity.

3. Correlate

- Did multiple users receive the same incorrect IP?
- Were phishing or malware alerts triggered afterward?
- Did users connect to the suspicious IP?

4. Enrich

- Check the reputation of **185.221.x.x**.
- Verify the legitimate DNS records using trusted DNS sources.

5. Decide

- If a legitimate domain resolves to a malicious IP, this is a strong indicator of **DNS Poisoning**.

6. Escalate

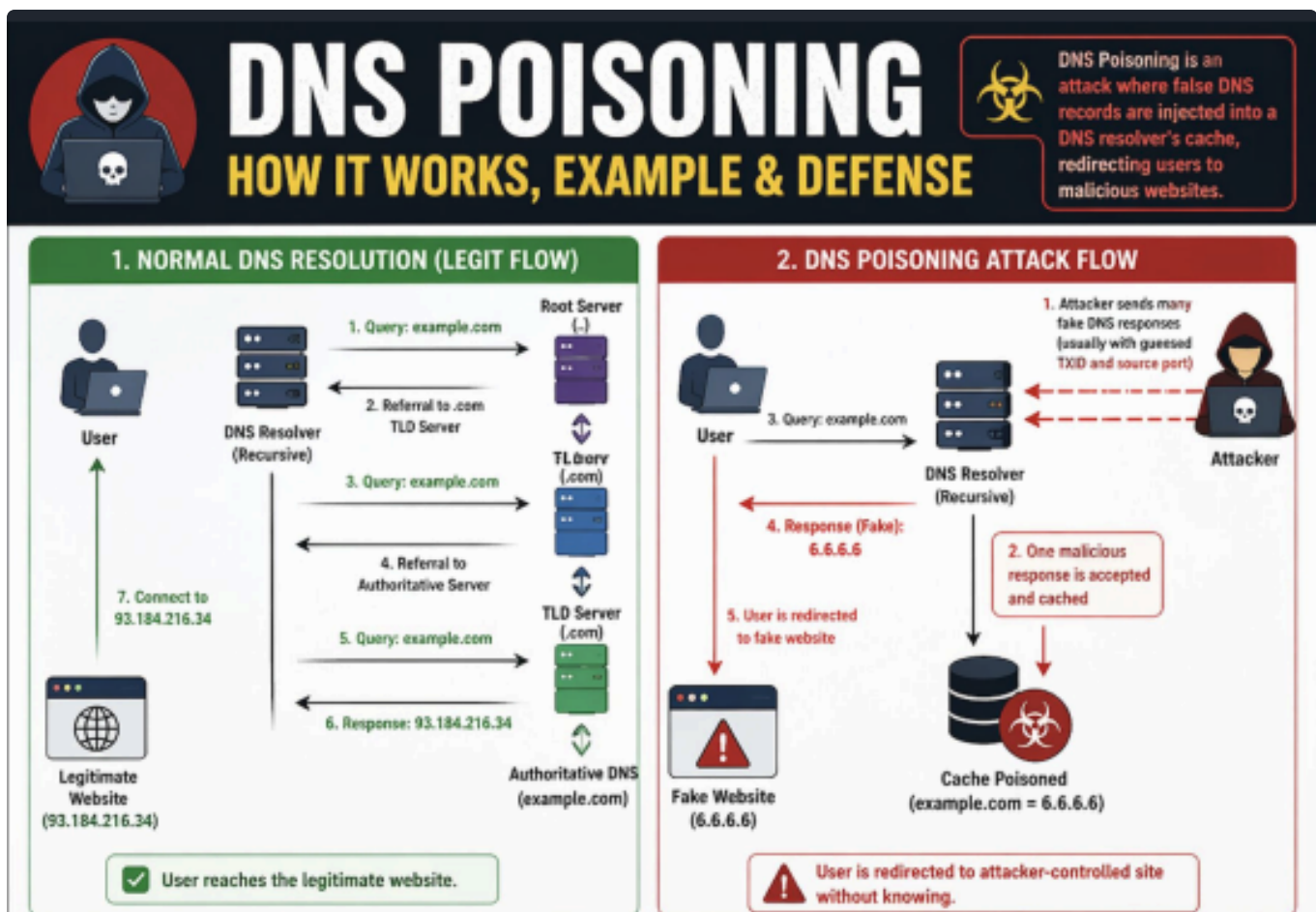
- Flush the DNS cache.
- Correct the DNS records.
- Block the malicious IP.
- Notify the DNS/network administrators.
- Investigate affected endpoints for phishing or malware infection.

Easy Trick to Remember

Normal DNS	DNS Poisoning
Correct Domain → Correct IP ✓	Correct Domain → Wrong IP ✗
User reaches real website	User reaches fake website

DNS Poisoning is an attack in which an attacker injects fake DNS responses so that a legitimate domain name resolves to a malicious IP address. This redirects users to fake websites where attackers can steal credentials, distribute malware, or conduct phishing attacks. From a SOC perspective, analysts detect DNS poisoning by identifying unexpected DNS resolutions, mismatched IP addresses for trusted domains, and correlating DNS logs with proxy, firewall, and endpoint alerts to confirm malicious redirection.

How it works



1. Normal DNS Resolution (Left Side)

User

|

```
1. Query: example.com
  |
DNS Resolver
  |
Root Server
  |
TLD Server (.com)
  |
Authoritative DNS
  |
Returns Correct IP
93.184.216.34
  |
User connects to the
Legitimate Website ✅
```

Steps

1. User requests **example.com**.
 2. DNS Resolver asks the Root Server.
 3. Root Server points to the **.com TLD Server**.
 4. TLD Server points to the **Authoritative DNS Server**.
 5. Authoritative DNS returns the **correct IP address**.
 6. DNS Resolver caches the result.
 7. User reaches the **real website**.
-

2. DNS Poisoning Attack (Right Side)

```
Attacker
  |
Sends Fake DNS Response
  |
DNS Resolver
  |
Caches Fake IP
6.6.6.6
  |
User requests example.com
  |
DNS Resolver returns
Fake IP
```

User is redirected to
Fake Website ❌

Steps

1. The attacker predicts or races the legitimate DNS response and sends a **fake DNS reply**.
 2. The DNS resolver **accepts and caches** the fake response (if the attack succeeds).
 3. The user requests **example.com**.
 4. The DNS resolver returns the **fake IP (6.6.6.6)** instead of the real one.
 5. The user unknowingly visits the **attacker-controlled website**.
-

Why is DNS Poisoning Dangerous?

The attacker can:

- 🖱️ Redirect users to **phishing websites**.
 - 🔑 Steal usernames and passwords.
 - 💳 Steal banking or payment information.
 - 🦠 Deliver malware or ransomware.
-

SOC Indicators

A SOC analyst should watch for:

- Trusted domains resolving to **unexpected IP addresses**.
 - Multiple users redirected to the same unknown IP.
 - DNS cache entries changing unexpectedly.
 - Increased phishing or malware alerts after DNS lookups.
 - DNS responses that don't match authoritative DNS records.
-

Example SOC Scenario

User: Alice

Requested:
company.com

Expected IP:
104.20.10.5

Returned IP:
185.221.x.x

SOC Analysis (6-Step Workflow)

1. Validate

- Confirm the DNS response.
- Compare the returned IP with the legitimate DNS record.

2. Investigate

- Review DNS server logs.
- Check proxy and firewall logs to see where users connected.

3. Correlate

- Determine whether multiple users received the same fake IP.
- Check EDR, IDS/IPS, and SIEM for related alerts.

4. Enrich

- Check the reputation of **185.221.x.x**.
- Verify the correct DNS records from authoritative sources.

5. Decide

- If a trusted domain resolves to a malicious IP, classify it as **DNS Poisoning (True Positive)**.

6. Escalate

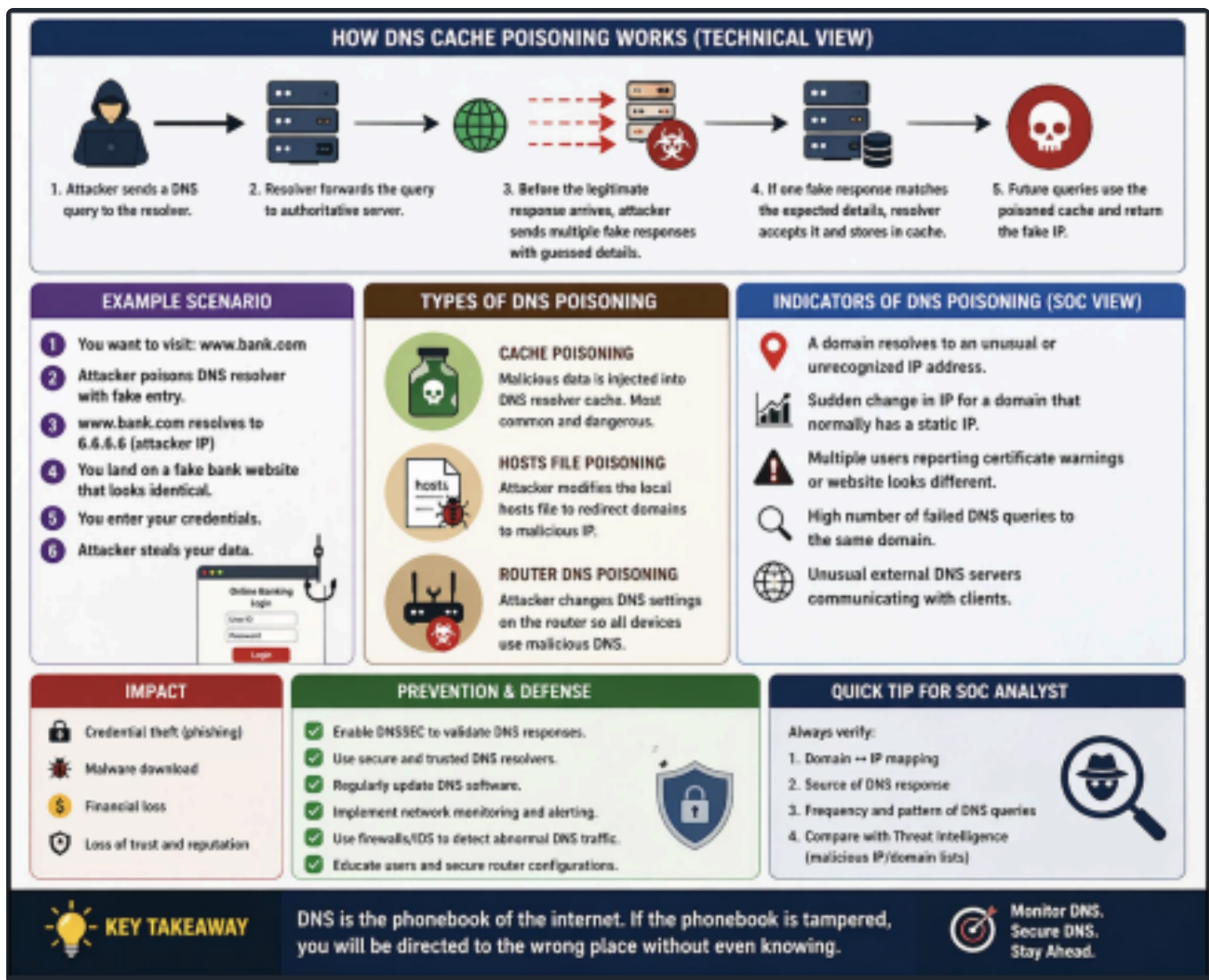
- Flush the DNS cache.
- Correct the DNS records.
- Block the malicious IP.
- Notify the DNS/network administrators.

- Check affected systems for phishing or malware.

Easy Trick to Remember

Normal DNS	DNS Poisoning
Domain → Correct IP → Real Website ✓	Domain → Fake IP → Fake Website ✗

DNS Poisoning, also known as **DNS Cache Poisoning**, is an attack where an attacker tricks a DNS resolver into caching a fake DNS response. As a result, users requesting a legitimate domain are redirected to a malicious IP address instead of the real website. The attack is commonly used for phishing, credential theft, and malware delivery. From a SOC perspective, analysts detect DNS poisoning by monitoring DNS logs for unexpected IP resolutions, validating DNS records against authoritative sources, and correlating DNS events with firewall, proxy, IDS/IPS, and endpoint alerts.



1. User → DNS Query
2. DNS Resolver asks Authoritative DNS
3. Attacker sends a Fake DNS Response
4. Resolver accepts the fake response and stores it in its cache
5. Future users receive the fake IP
6. Users are redirected to a fake website

Key Idea

The attacker **poisons the DNS cache**. After that, anyone requesting that domain may be redirected to the attacker's server until the cached record expires or is cleared.

Example Scenario

User visits:
www.bank.com

Expected IP:
104.20.x.x

Fake IP:
6.6.6.6

|



Fake Banking Website

|

User enters username & password

|

Attacker steals credentials

This is a classic **phishing attack** using DNS poisoning.

Types of DNS Poisoning

1. DNS Cache Poisoning

- The attacker injects a fake DNS record into the **DNS resolver's cache**.
 - All users relying on that resolver may receive the fake IP.
-

2. Host File Poisoning

- The attacker modifies the **hosts file** on a victim's computer.
- The operating system uses the fake entry before querying DNS.

Example:

www.bank.com → 6.6.6.6

3. Router DNS Poisoning

- The attacker changes the **DNS settings** on a home or office router.
 - Every connected device uses the attacker's chosen DNS server.
-

SOC Indicators of DNS Poisoning

A SOC analyst should investigate when they see:

1. Domain Resolves to an Unexpected IP

Example:

```
google.com
```

```
Expected:
```

```
142.x.x.x
```

```
Returned:
```

```
185.x.x.x
```

2. Sudden Change in DNS Responses

- A trusted domain suddenly resolves to a different IP without any planned infrastructure change.
-

3. Users Reporting Certificate Warnings

Examples:

- "Your connection is not private."
- Invalid SSL/TLS certificate.

This may indicate users are being redirected to a fake website.

4. High Number of Failed DNS Queries

A sudden spike in DNS failures may indicate DNS manipulation or misconfiguration.

5. Unusual External DNS Servers

Internal systems suddenly start communicating with unknown public DNS servers instead of the organization's approved DNS servers.

Impact

If DNS poisoning succeeds, it can lead to:

-  Credential theft (phishing).
 -  Malware infection.
 -  Financial fraud.
 -  Loss of customer trust and reputation.
-

Prevention & Defense

Organizations can reduce the risk by:

- Enable **DNSSEC** (Domain Name System Security Extensions).
 - Use trusted DNS resolvers.
 - Keep DNS servers patched and updated.
 - Monitor DNS traffic and logs.
 - Flush DNS caches if poisoning is suspected.
 - Use firewalls and IDS/IPS to detect abnormal DNS activity.
-

SOC Investigation Workflow

Validate

- Verify the suspicious DNS response.
- Compare it with the expected DNS record.

Investigate

- Check:
 - DNS server logs.
 - Resolver cache.
 - Firewall and proxy logs.

Correlate

- Review:
 - IDS/IPS alerts.
 - Endpoint logs.
 - User reports (SSL warnings or phishing pages).

Enrich

- Check the returned IP using threat intelligence.
- Confirm the correct IP from the authoritative DNS server.

Decide

- If a legitimate domain resolves to a malicious IP, classify it as **DNS Cache Poisoning**.

Escalate

- Flush the DNS cache.
- Restore the correct DNS records.
- Block the malicious IP.
- Notify the DNS/network administrators.
- Check affected endpoints for compromise.

Quick Tip for SOC Analysts

When investigating DNS-related alerts, always ask:

1. **Is the domain resolving to the correct IP?**
2. **Has the DNS response changed unexpectedly?**
3. **Are multiple users affected?**

4. Are there phishing, SSL certificate, or malware alerts associated with the DNS activity?
5. Does the returned IP have a malicious reputation?

DNS Cache Poisoning is an attack where an attacker injects a fake DNS response into a DNS resolver's cache, causing legitimate domains to resolve to malicious IP addresses. This can redirect users to phishing sites, steal credentials, or deliver malware. From a SOC perspective, key indicators include unexpected DNS resolutions, sudden changes in DNS responses, SSL certificate warnings, high DNS failure rates, and communication with unusual DNS servers. Analysts validate the DNS records, correlate DNS events with firewall, proxy, IDS/IPS, and endpoint logs, and take steps to restore the correct DNS configuration if poisoning is confirmed.

Real Attack Flow (DNS Poisoning)

1. Attacker poisons the DNS cache
2. User types: bank.com
3. DNS returns the attacker's IP
4. Fake bank login page is displayed
5. User enters username & password
6. Attacker steals the credentials

SOC Indicators (DNS Poisoning)

A SOC analyst should look for the following signs:

1. Unexpected DNS Resolution

A trusted domain resolves to an **unknown or suspicious IP**.

Example:

Domain: bank.com

Expected IP: 104.20.x.x

Returned IP: 185.221.x.x

 **Indicator:** Possible DNS poisoning.

2. Multiple Users Redirected to the Same Fake IP

Many users trying to access the same website are redirected to the **same suspicious IP**.

Example:

User1 → bank.com → 185.221.x.x

User2 → bank.com → 185.221.x.x

User3 → bank.com → 185.221.x.x

 Could indicate a poisoned DNS cache.

3. SSL/TLS Certificate Warnings

Users report messages like:

- "Your connection is not private."
- "Certificate is not trusted."
- "Certificate mismatch."

 A fake website often cannot present the legitimate website's certificate.

4. Sudden DNS Record Changes

A domain suddenly starts resolving to a different IP without any planned infrastructure change.

5. Connections to Unknown IP Addresses

Firewall or proxy logs show users connecting to an unexpected external IP after a DNS lookup.

6. Phishing or Malware Alerts

After users visit a website, the IDS/IPS, proxy, or EDR generates alerts for:

- Phishing
 - Malware downloads
 - Command-and-Control (C2) communication
-

Example SOC Scenario

User: Alice

Domain: bank.com

Expected IP: 104.20.10.5

Returned IP: 185.221.x.x

Proxy:

Visited fake login page

EDR:

Credential stealing malware detected

Conclusion

DNS Poisoning leading to a phishing attack and credential theft.

SOC Analysis (Your Workflow)

1. Validate

- Verify DNS logs.

- Compare the returned IP with the legitimate DNS record.

2. Investigate

- Check:
 - DNS server logs
 - Firewall logs
 - Proxy logs
 - Endpoint (EDR) logs

3. Correlate

- Determine whether multiple users were redirected.
- Check for SSL certificate warnings and phishing or malware alerts.

4. Enrich

- Check the reputation of the returned IP.
- Verify the legitimate DNS records from the authoritative DNS server.

5. Decide

- If a legitimate domain resolves to a malicious IP and users are redirected to a fake site, classify it as **DNS Poisoning (True Positive)**.

6. Escalate

- Flush the DNS cache.
- Restore the correct DNS records.
- Block the malicious IP and domain.
- Notify the DNS/network administrators.
- Reset passwords for affected users and investigate endpoints for compromise.

DNS Poisoning is an attack where an attacker manipulates DNS responses so that a legitimate domain resolves to a malicious IP address. This redirects users to fake websites where credentials can be stolen or malware can be delivered. From a SOC perspective, key indicators include unexpected DNS resolutions, multiple users being redirected to the same suspicious IP, SSL certificate

warnings, sudden DNS record changes, and related phishing or malware alerts. A SOC analyst validates the DNS records, correlates DNS, firewall, proxy, and endpoint logs, and escalates the incident if DNS poisoning is confirmed.

Real SOC Scenario

User Complaint

User:
"Google looks different."

At first, this may seem like a simple user issue, but to a SOC analyst, it can be a **security incident**.

Investigation

DNS logs show:

Domain:
google.com

Returned IP:
185.221.x.x (Unknown IP)

Instead of resolving to Google's legitimate IP addresses, **google.com** resolves to an **unknown IP**.

Conclusion

Possible DNS Poisoning Attack

The user is likely being redirected to a **fake Google website** controlled by an attacker.

SOC Analysis (Your 6-Step Workflow)

1. Validate

- Confirm the user's complaint.
 - Verify the DNS logs.
 - Compare the returned IP with Google's legitimate DNS records.
-

2. Investigate

Check:

- DNS server logs.
- Firewall logs.
- Proxy logs.
- Browser history.
- Endpoint (EDR) logs.

Questions:

- Is only one user affected?
 - Are multiple users receiving the same incorrect IP?
-

3. Correlate

Compare:

- DNS logs.
 - Firewall connections to the suspicious IP.
 - Proxy logs showing access to the fake website.
 - IDS/IPS alerts.
 - EDR alerts for malware or credential theft.
-

4. Enrich

- Check the reputation of the returned IP.
- Verify Google's official IP addresses from authoritative DNS servers.

- Determine whether the suspicious IP is associated with phishing or malware.
-

5. Decide

Evidence:

- Trusted domain (**google.com**) resolved to an unknown IP.
- User noticed an unusual website.

Decision: True Positive – Suspected DNS Poisoning

6. Escalate

- Flush the DNS cache.
 - Restore the correct DNS records.
 - Block the malicious IP.
 - Reset passwords if users entered credentials.
 - Notify the DNS/Network and Incident Response teams.
 - Check affected endpoints for malware.
-

SOC Log Example

User Complaint:

"Google looks different."

DNS Log:

Query: google.com

Expected IP: 142.250.x.x

Returned IP: 185.221.x.x

Proxy Log:

Visited fake Google page

Firewall:

Allowed connection to 185.221.x.x

EDR:
No malware detected

Final Conclusion

DNS Poisoning / DNS Cache Poisoning leading to a phishing attempt.

Analyst Thinking

When a user says:

"This website looks different."

Don't assume it's just a browser issue.

Ask yourself:

- Is the DNS resolving to the correct IP?
- Did the user receive SSL certificate warnings?
- Are other users reporting the same issue?
- Is the IP known to be malicious?
- Has the DNS cache or DNS server been poisoned?

If a user reports that "Google looks different," I would first verify the DNS resolution. If the DNS logs show that **google.com** is resolving to an unknown or malicious IP address instead of Google's legitimate IPs, I would suspect **DNS Poisoning**. I would validate the DNS records, correlate DNS logs with firewall, proxy, IDS/IPS, and endpoint logs, check whether other users are affected, and escalate the incident if confirmed. The goal is to restore correct DNS resolution and prevent credential theft or malware infection.

DNS Footprinting & DNS Poisoning

Feature	Footprinting	Poisoning
Stage	Recon	Attack
Goal	Info gathering	Redirection
Visibility	Low	Medium
Impact	Planning	Compromise

SOC Analyst Mindset

✗ Don't ask:

| "What domain is this?"

✓ Ask:

| "Why is this domain being queried?"

Because the **context** determines whether the activity is normal or suspicious.

Think Like an Analyst

1. Is this a normal business domain?

```
Query:
login.microsoftonline.com
```

Question:

- Is the user logging into Microsoft 365?

✓ **Likely Normal**

2. Is the user querying many subdomains?

```
admin.company.com
vpn.company.com
dev.company.com
test.company.com
```

Question:

- Why is one IP querying so many subdomains?

🚨 **Possible DNS Footprinting**

3. Is a trusted domain resolving to a strange IP?

```
google.com  
↓  
185.221.x.x
```

Question:

- Why isn't Google resolving to Google's IP?



Possible DNS Poisoning

4. Is an endpoint making repeated DNS queries to random domains?

```
abc123.xyz  
qwe789.top  
xzy456.cc
```

Question:

- Why is this host querying random domains every few seconds?



Possible Malware / Command & Control (C2) using DNS

Questions Every SOC Analyst Should Ask

Whenever you see DNS logs, ask:

1. **Who** made the DNS query?
 - Which user?
 - Which endpoint?
 - Which source IP?
2. **What** domain was queried?
 - Trusted?
 - Newly registered?
 - Malicious?

3. **Why** was it queried?
 - Normal browsing?
 - Email?
 - Malware?
 - Reconnaissance?
 4. **When** did it happen?
 - During business hours?
 - After a phishing email?
 - After a malware alert?
 5. **Where** did it go?
 - Expected IP?
 - Unknown IP?
 - Malicious country?
 6. **What happened next?**
 - File download?
 - Login attempt?
 - Malware execution?
 - Data exfiltration?
-

Example 1 (Normal)

User:

John

Query:

www.google.com

Result:

Successful

Thinking:

- User is browsing the web.
- No other alerts.

 **Likely Benign**

Example 2 (Reconnaissance)

Source IP:

45.12.x.x

Queries:

admin.company.com

vpn.company.com

mail.company.com

dev.company.com

Thinking:

- Why is one external IP querying multiple subdomains?



DNS Footprinting

Example 3 (DNS Poisoning)

User:

Alice

Query:

google.com

Returned IP:

185.221.x.x

Thinking:

- Why is Google resolving to an unknown IP?



DNS Poisoning

Example 4 (Malware)

Host:

PC-102

Queries:

```
abc123.xyz  
def987.top  
ghi456.cc
```

Thinking:

- Why is the endpoint contacting random domains?

Possible Malware / C2 Communication

Golden Rule for SOC Analysts

Logs tell you *what* happened.

An analyst asks *why* it happened.

This shift—from reading logs to understanding the reason behind them—is what distinguishes a SOC analyst from someone who simply reviews alerts.

When I analyze DNS logs, I don't just look at the domain name. I ask **why the domain is being queried**. A single query to a trusted domain may be normal, but repeated queries for many subdomains can indicate DNS footprinting, a trusted domain resolving to an unexpected IP can indicate DNS poisoning, and frequent queries to random domains may indicate malware or command-and-control communication. My goal is to understand the context, correlate it with other security logs, and determine whether the activity is benign or malicious.

APT (Advanced Persistent Threat)

An **Advanced Persistent Threat (APT)** is a **targeted, long-term cyberattack** in which attackers gain unauthorized access to a network and **remain hidden for weeks, months, or even years** while stealing data or conducting espionage.

Simple Definition:

APT = Advanced + Persistent + Threat

1. Advanced

The attackers use **sophisticated techniques** to avoid detection.

Examples:

- Custom malware
- Zero-day exploits
- Living-off-the-Land (using legitimate system tools)
- Privilege escalation
- Defense evasion

Goal: Bypass security controls without being detected.

2. Persistent

The attackers **maintain long-term access** to the victim's network.

They:

- Create backdoors.
- Add persistence mechanisms (scheduled tasks, registry keys, services).
- Move laterally to other systems.
- Return even after partial cleanup.

Goal: Stay hidden and continue accessing the network.

3. Threat

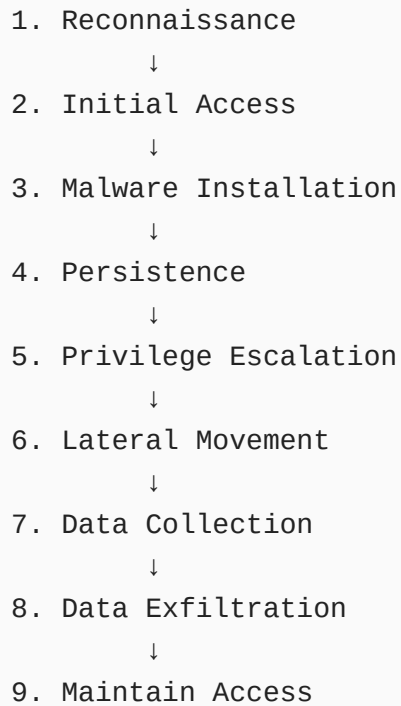
The attackers are usually **well-funded and highly skilled**.

Examples:

- Nation-state groups.
- Cyber espionage groups.
- Organized cybercriminal groups.

Goal: Steal sensitive information, intellectual property, financial data, or disrupt operations.

APT Attack Lifecycle



SOC Perspective

A SOC analyst looks for signs such as:

- Unusual login activity.
- Repeated connections to unknown external IPs.
- New administrator accounts.
- Lateral movement between systems.
- Persistent scheduled tasks or services.
- Large outbound data transfers (data exfiltration).
- Command-and-Control (C2) traffic.

Example SOC Scenario

Day 1:
User opens phishing email.

↓

Malware installed.

↓

Week 2:

New admin account created.

↓

Week 3:

Multiple internal servers accessed.

↓

Week 4:

5 GB of sensitive data sent to an external IP.

Conclusion



Possible Advanced Persistent Threat (APT)

The attacker has remained in the environment for an extended period and is stealing data.

SOC Analysis (6-Step Workflow)

1. Validate

- Confirm alerts from SIEM, EDR, IDS, and firewall.
- Verify that the events are related.

2. Investigate

- Identify the initial entry point.
- Determine which systems and accounts are affected.
- Check persistence mechanisms and lateral movement.

3. Correlate

- Correlate:

- Email logs
- DNS logs
- Firewall logs
- Proxy logs
- EDR logs
- Authentication logs

4. Enrich

- Check IPs, domains, file hashes, and malware indicators using threat intelligence.

5. Decide

- If there is evidence of long-term unauthorized access, persistence, and data theft, classify it as a **suspected APT**.

6. Escalate

- Isolate affected systems.
- Block malicious IPs and domains.
- Remove persistence mechanisms.
- Notify the Incident Response team.
- Begin containment and forensic investigation.

An **Advanced Persistent Threat (APT)** is a targeted, long-term cyberattack in which skilled attackers gain unauthorized access to a network and remain hidden for an extended period. They use advanced techniques such as custom malware, zero-day exploits, persistence mechanisms, and lateral movement to avoid detection while stealing sensitive data. From a SOC perspective, indicators include persistent access, unusual authentication activity, command-and-control communication, lateral movement, and data exfiltration. Analysts correlate multiple log sources to detect and respond to these attacks before significant damage occurs.

How Advanced Persistent Threat (APT) works



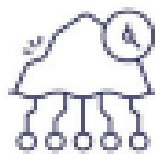
Introduce Malware



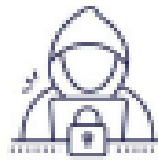
Gain Access



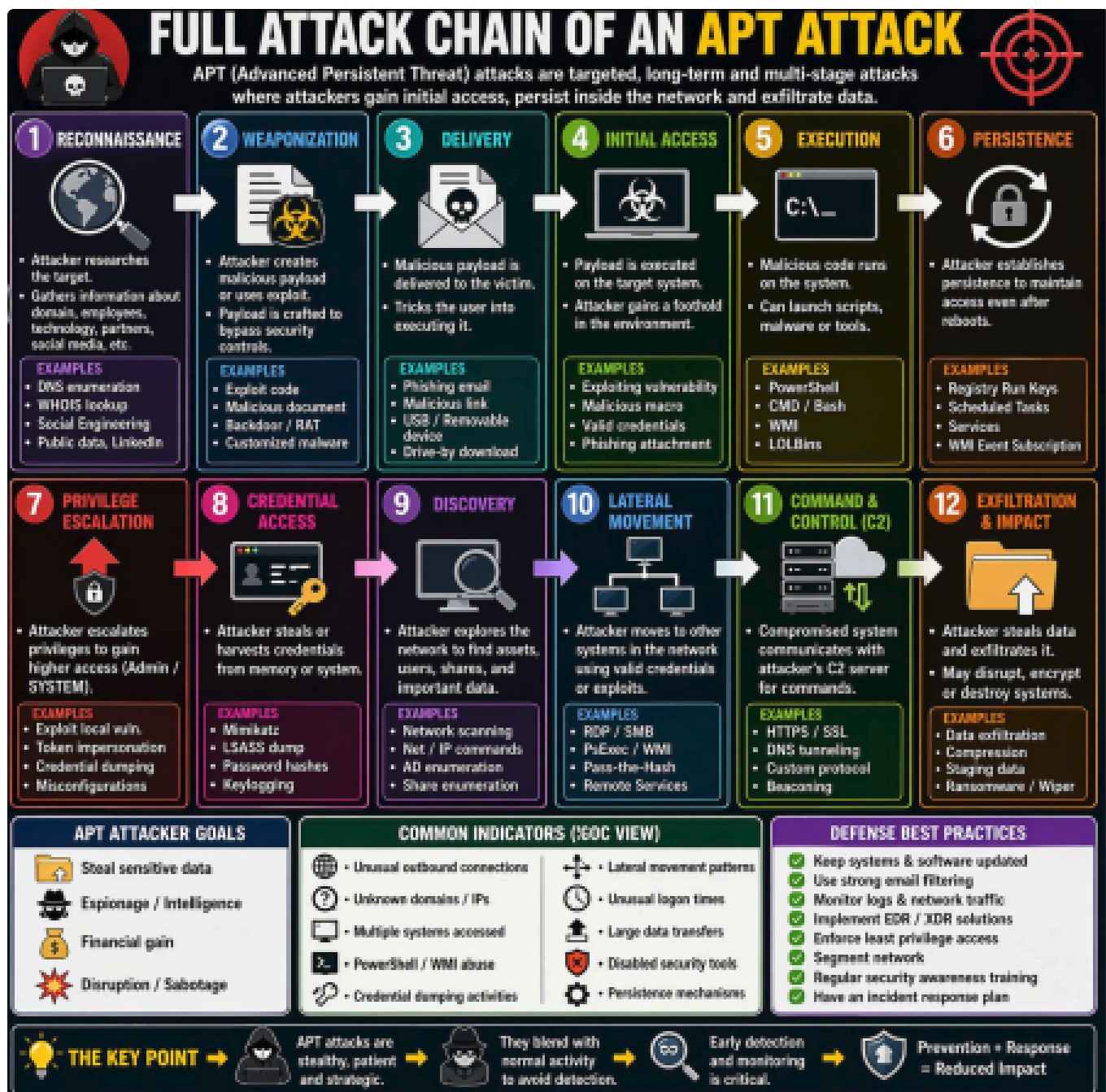
Administration Rights



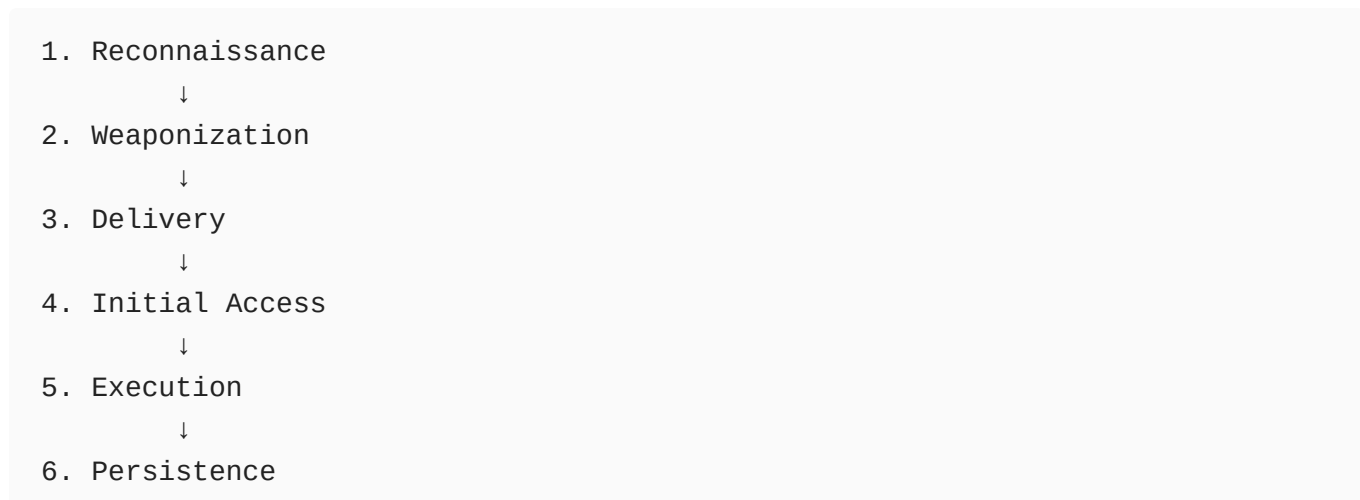
Dig Deeper

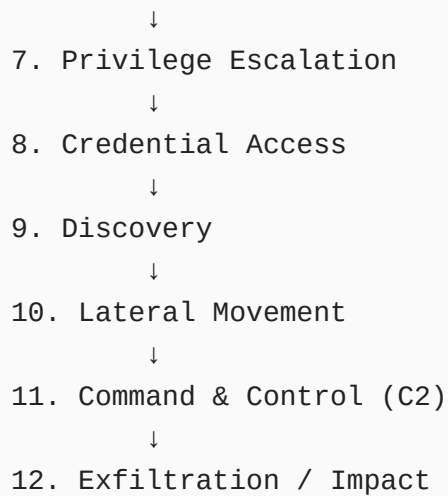


Hacker Remain in Place



Full APT Attack Chain





1. Reconnaissance

What attacker does

- Collects information about the target.
- Searches for employees, domains, subdomains, VPNs, technologies, and email addresses.

Examples

- DNS Footprinting
- WHOIS lookup
- LinkedIn/OSINT
- Social engineering

SOC Indicators

- Multiple DNS queries.
- Port scanning.
- Enumeration of subdomains.
- External IP probing public services.

2. Weaponization

What attacker does

Creates the attack payload.

Examples

- Malicious Office document.
- Trojanized PDF.
- Custom malware.
- Ransomware payload.

SOC Indicators

Usually **no logs** because this happens on the attacker's system.

3. Delivery

What attacker does

Sends the payload to the victim.

Examples

- Phishing email.
- Malicious attachment.
- Malicious link.
- USB device.

SOC Indicators

- Suspicious email.
 - Blocked attachment.
 - URL reputation alerts.
 - Email gateway detections.
-

4. Initial Access

What attacker does

Gets into the victim's system.

Examples

- User opens phishing attachment.
- Exploits VPN vulnerability.
- Exploits public-facing application.

SOC Indicators

- Successful phishing.
 - VPN login from unusual country.
 - Exploit alerts.
 - New device access.
-

5. Execution

What attacker does

Runs malicious code.

Examples

- PowerShell.
- CMD.
- WScript.
- Malicious EXE.

SOC Indicators

- Suspicious PowerShell.
 - Script execution.
 - New process creation.
 - EDR alerts.
-

6. Persistence

What attacker does

Ensures continued access after reboot.

Examples

- Registry Run Keys.
- Scheduled Tasks.
- Services.
- Startup folders.

SOC Indicators

- New scheduled task.
 - New Windows service.
 - Registry modifications.
 - Startup persistence detected.
-

7. Privilege Escalation

What attacker does

Obtains higher privileges.

Examples

- Exploiting vulnerabilities.
- Token impersonation.
- UAC bypass.

SOC Indicators

- User suddenly becomes Administrator.
 - Privilege escalation alerts.
 - Sensitive account changes.
-

8. Credential Access

What attacker does

Steals usernames and passwords.

Examples

- Mimikatz.
- LSASS memory dump.
- SAM database access.
- Password dumping.

SOC Indicators

- LSASS access.
 - Credential dumping detection.
 - Authentication anomalies.
-

9. Discovery

What attacker does

Maps the internal network.

Examples

- `net user`
- `ipconfig`
- `net view`
- Active Directory enumeration

SOC Indicators

- Enumeration commands.
 - Large number of LDAP queries.
 - Network scanning.
 - Discovery tool execution.
-

10. Lateral Movement

What attacker does

Moves to other systems.

Examples

- RDP
- SMB
- PsExec
- WMI

SOC Indicators

- Multiple RDP logins.
 - PsExec execution.
 - SMB connections between hosts.
 - Internal authentication failures.
-

11. Command & Control (C2)

What attacker does

Communicates with the attacker's server.

Examples

- HTTPS beaconing.
- DNS tunneling.
- Encrypted C2 traffic.

SOC Indicators

- Periodic outbound connections.
 - Connections to malicious IPs/domains.
 - DNS tunneling.
 - Beaconing every few minutes.
-

12. Exfiltration / Impact

What attacker does

Steals or encrypts data.

Examples

- Upload confidential files.
- Ransomware encryption.
- Destroy backups.

SOC Indicators

- Large outbound traffic.
- Data sent to cloud storage or unknown IPs.
- File encryption activity.
- Data Loss Prevention (DLP) alerts.

SOC Analyst Mindset

Whenever you receive an alert, ask:

Question	Example
Where is the attacker now?	Delivery? Persistence? C2?
What happened before this?	Phishing email? VPN login?
What is the next likely step?	Lateral movement? Data theft?
How can I stop them now?	Block IP, isolate host, disable account

Easy Memory Trick

Stage	Goal
Reconnaissance	Learn about the target
Weaponization	Build the malware
Delivery	Send the malware
Initial Access	Get inside
Execution	Run the malware
Persistence	Stay inside
Privilege Escalation	Become Admin

Stage	Goal
Credential Access	Steal passwords
Discovery	Explore the network
Lateral Movement	Spread to other systems
Command & Control	Communicate with attacker
Exfiltration	Steal data or cause damage

An **APT attack** is a long-term, targeted attack that follows multiple stages. It begins with **reconnaissance**, where attackers gather information, followed by **weaponization** and **delivery** of a malicious payload. After gaining **initial access**, they **execute** malware, establish **persistence**, **escalate privileges**, and **steal credentials**. They then perform **discovery** to understand the network, use **lateral movement** to spread to other systems, establish **command and control (C2)** communications, and finally **exfiltrate data** or disrupt operations. As a SOC analyst, my goal is to detect and interrupt the attack as early as possible by correlating alerts from SIEM, EDR, IDS/IPS, DNS, firewall, proxy, and authentication logs before the attacker reaches the exfiltration stage.

SOC Indicators of an APT Attack

Unlike ransomware or DDoS attacks, an **APT attack is stealthy**. Attackers try to remain unnoticed while gradually moving through the network.

Key SOC Indicators

1. Low and Slow Activity

- Small actions spread over days or weeks.
- Avoids triggering security alerts.

Example

Day 1: Phishing email
Day 5: New scheduled task
Day 10: New admin account
Day 20: Data exfiltration



Indicator: Long-term suspicious behavior.

2. Unusual Login Patterns

Examples:

- Login at unusual hours.
- Login from a new country.
- Impossible travel.
- Admin account used on unexpected systems.



Indicator: Possible compromised account.

3. Internal Lateral Movement

The attacker moves from one system to another.

Examples:

- RDP
- SMB
- PsExec
- WMI



Indicator: One compromised host accessing many internal systems.

4. Suspicious PowerShell Usage

Attackers often use **PowerShell** because it is a legitimate Windows tool.

Examples:

- Downloading malware.
- Executing encoded commands.
- Running scripts from memory.



Indicator: Encoded or unusual PowerShell commands.

5. Data Exfiltration

The attacker sends sensitive files outside the organization.

Examples:

- Large uploads.
- Connections to cloud storage.
- Data sent to unknown external IPs.



Indicator: Unusual outbound traffic.

6. Unknown Domains (Command & Control - C2)

The infected system periodically contacts an unknown domain or IP.

Example:

```
PC-101
  |
Every 5 minutes
  |
abc123.xyz
```



Indicator: Malware beaconing to a C2 server.

Real SOC Scenario

```
User opens phishing email
      ↓
PowerShell executed
      ↓
Mimikatz dumps credentials
      ↓
Admin login detected
      ↓
RDP to multiple servers
```



Data transfer to external IP

Why This Is an APT

This is **not a single isolated event**. Each event is linked and represents a different stage of the attack.

Event	MITRE ATT&CK Tactic
User opens phishing email	Initial Access
PowerShell executed	Execution
Mimikatz dumps credentials	Credential Access
Admin login detected	Privilege Escalation / Valid Accounts
RDP to multiple servers	Lateral Movement
Data transfer to external IP	Exfiltration



Together, these events form an **APT-style attack chain**.

SOC Analysis (6-Step Workflow)

1. Validate

- Confirm each alert is genuine.
- Verify timestamps and affected host.

2. Investigate

- Identify the phishing email.
- Determine whether PowerShell executed successfully.
- Check if Mimikatz ran and what credentials were stolen.

3. Correlate

Review:

- Email logs
- EDR logs
- Windows Event Logs

- Authentication logs
- Firewall logs
- Proxy logs
- VPN logs

This helps build the complete attack timeline.

4. Enrich

- Check the external IP and domains using threat intelligence.
- Investigate file hashes and PowerShell commands.
- Identify the malware family, if any.

5. Decide

Evidence shows:

- Initial compromise
- Credential theft
- Lateral movement
- Data exfiltration

✅ **Decision: True Positive – Suspected APT Attack**

6. Escalate

- Isolate affected endpoints.
- Disable compromised accounts.
- Block malicious IPs/domains.
- Remove persistence mechanisms.
- Notify the Incident Response team.
- Begin forensic investigation.

SOC Analyst Mindset

When multiple alerts appear, **don't investigate them separately.**

Instead ask:

- **Are these alerts connected?**
- **Is this following an attack chain?**

- **Where is the attacker now?**
- **What is the next likely step?**

A SOC analyst's job is to **connect the dots**, not just respond to individual alerts.

Interview Answer (45 Seconds)

In an APT attack, the indicators are usually **low and slow activity, unusual logins, lateral movement, suspicious PowerShell execution, credential dumping, unknown C2 communications, and data exfiltration**. For example, if a user opens a phishing email, followed by PowerShell execution, Mimikatz credential dumping, an unexpected admin login, RDP access to multiple servers, and finally a large data transfer to an external IP, I would not treat these as separate alerts. I would correlate them into a single attack timeline, recognize them as an **APT-style attack chain**, and immediately initiate containment and incident response.

APT vs Normal Attack

Feature	Normal Attack	APT
Duration	Short	Long
Goal	Quick Gain	Strategic
Detection	Easier	Hard
Behavior	Noisy	Stealthy

SOC Analyst Mindset

When investigating, Don't think: "This is one alert"

Think: Is this part of a bigger attack chain?